

EPSS-TPG Experiment Results

1 What This Document Covers

This document reports the test-set results from the current round of EPSS-TPG experiments. The model and the input pipelines are explained in two companion documents that share the same vocabulary and notation: one walks through the dataset features, the other walks through the multi-view TPG formula. This document focuses on the numbers.

The experiments fall into five groups:

1. A 19-run text-source ablation on the four refreshed Sec4AI4Aec-EPSS-Enhanced datasets: GPT, Gemma, Mistral and DeepSeek. Mistral is new in this round; GPT and Gemma were re-fetched against the new schema; the older Llama variant was dropped because its schema is incompatible. The ablation should be 20 runs, but one cell is unrunnable (DeepSeek does not ship the CVSS-templated summary column), so 19 runs actually completed.
2. A 15-run text-source ablation on the three Megavul-branch datasets: Mega-GPT, Mega-Gemma and Mega-Mistral. Megavul is a commit-grounded vulnerability corpus with a much sparser positive class than the social-media datasets (about 1.7% versus 15.5% at the same EPSS binarisation threshold).
3. A cross-reference of the model’s highest-confidence test predictions against the live CISA KEV catalog (catalogVersion 2026.05.08, 1,590 CVEs) and the live FIRST EPSS API (queried 2026-05-12).
4. An NVD/KEV binary classification rerun on the older balanced dataset.
5. Two NVD/KEV temporal-shift evaluations: train on 2020–2022, test on 2023–2024.

The two text-source ablations and the KEV cross-reference are the main story; the NVD/KEV runs are kept for context.

2 The Social-Media Text-Source Ablation

2.1 Setup

The question we are answering: does feeding the model an LLM-generated summary of a CVE help, hurt, or do nothing, compared with just feeding it the CVE description? Each of the four social-media datasets ships the same CVE description plus three different LLM summaries:

- one summary built from every source link the dataset has for that CVE;
- one summary built only from GitHub URLs;

Variant	Flags passed at training time	What text the model actually sees
D	<code>--summary-source description</code>	The CVE description, nothing else. The baseline.
S_ALL	<code>--summary-only-tpg</code> <code>--summary-source all_sources</code>	Only the all-sources summary. CVEs without that summary are dropped, so the train and test sets shrink.
S_GIT	<code>--summary-only-tpg</code> <code>--summary-source github_urls</code>	Only the GitHub-URL summary. Most CVEs do not have one, so the test set drops to 339–360 samples instead of 1,385.
S_CVSS	<code>--summary-only-tpg</code> <code>--summary-source cvss_metrics</code>	Only the templated CVSS-metrics summary. Available for GPT, Gemma and Mistral; the DeepSeek dataset does not ship this column.
ALL	<code>--include-summary-in-tpg</code> <code>--summary-source combined</code>	The description plus all three summaries, joined with double newlines. The largest input by token count.

Table 1: The five settings used per dataset.

- one summary written from the CVSS metrics in templated form.

We trained the model under five settings per dataset, so the design is $4 \times 5 = 20$ runs.

Every run uses the same training command, with these flags: `--backbone multiview`, `--hybrid`, `--label-mode soft`, `--epochs 100` and `--no-epss-feature`. The `--no-epss-feature` flag matters: the soft target is the EPSS score itself, so the EPSS score and percentile must be removed from the tabular inputs. Otherwise the model would just learn to copy the input back as the prediction. Input channel size stays at 781 (13-D node-type one-hot plus 768-D SecBERT embedding); the tabular vector is 55-D without EPSS; the edge-type vocabulary is the base 13 (no security edges in this matrix).

Why 19 runs and not 20. The DeepSeek dataset has no CVSS-templated summary column. Zero records out of 9,218. So the DeepSeek S_cvss cell cannot be trained and is reported as “–” below. This is a missing-data fact about the DeepSeek dataset, not a training failure. The other 19 runs all completed.

2.2 Per-Run Numbers

Table 2: Test-set metrics for the 19 completed social-media runs.
The missing DeepSeek S_cvss cell is shown as “–”.

Dataset	Variant	PR-AUC	ROC-AUC	F1	Precision	Recall	Brier	N_{test}
GPT	D	0.8438	0.9438	0.8056	0.8113	0.8000	0.0491	1,385
GPT	S_all	0.6826	0.8991	0.6407	0.5426	0.7821	0.1004	1,143
GPT	S_git	0.7048	0.9374	0.7846	0.7083	0.8793	0.0691	339
GPT	S_cvss	0.5358	0.8584	0.5437	0.5529	0.5349	0.1019	1,385
GPT	ALL	0.8003	0.9442	0.7440	0.7739	0.7163	0.0588	1,385
Gemma	D	0.8356	0.9338	0.8159	0.8178	0.8140	0.0505	1,385
Gemma	S_all	0.7332	0.9176	0.5134	0.8272	0.3722	0.0762	1,148
Gemma	S_git	0.7186	0.8968	0.5684	0.7500	0.4576	0.0913	360
Gemma	S_cvss	0.5421	0.8654	0.5558	0.5680	0.5442	0.1021	1,385
Gemma	ALL	0.8341	0.9494	0.7669	0.8315	0.7116	0.0533	1,385
Mistral	D	0.8378	0.9448	0.7990	0.8227	0.7767	0.0499	1,385

Dataset	Variant	PR-AUC	ROC-AUC	F1	Precision	Recall	Brier	N_{test}
Mistral	S_all	0.6273	0.8887	0.4901	0.6966	0.3780	0.0838	1,099
Mistral	S_git	0.6266	0.8828	0.5319	0.7143	0.4237	0.0990	359
Mistral	S_cvss	0.5510	0.8697	0.5383	0.5321	0.5446	0.1031	1,354
Mistral	ALL	0.8313	0.9469	0.7656	0.7882	0.7442	0.0549	1,385
DeepSeek	D	0.8326	0.9374	0.8000	0.7739	0.8279	0.0538	1,385
DeepSeek	S_all	0.6764	0.8922	0.6743	0.6941	0.6556	0.0771	1,147
DeepSeek	S_git	0.6937	0.8580	0.6061	0.7500	0.5085	0.0844	360
DeepSeek	S_cvss	–	–	–	–	–	–	–
DeepSeek	ALL	0.8112	0.9377	0.7549	0.7979	0.7163	0.0579	1,385

2.3 Means by Variant

Variant	n	Mean PR-AUC	Mean change vs D
D	4	0.8374	–
S_ALL	4	0.6799	–0.1576
S_GIT	4	0.6859	–0.1515
S_CVSS	3	0.5430	–0.2944
ALL	4	0.8192	–0.0182

Table 3: Mean PR-AUC across the four social-media datasets. S_cvss is over three datasets only because DeepSeek does not ship that summary column.

A small caveat before reading the deltas. S_ALL and S_GIT drop CVEs whose chosen summary is empty, so their test sets are smaller. S_GIT is evaluated on 339–360 samples per run instead of 1,385; S_ALL on 1,099–1,148. The PR-AUC numbers are valid for the subsets they were measured on, but the deltas against D are not perfectly like-for-like.

2.4 Per-Dataset PR-AUC

Dataset	D	S_ALL	S_GIT	S_CVSS	ALL
GPT	0.8438	0.6826	0.7048	0.5358	0.8003
Gemma	0.8356	0.7332	0.7186	0.5421	0.8341
Mistral	0.8378	0.6273	0.6266	0.5510	0.8313
DeepSeek	0.8326	0.6764	0.6937	–	0.8112
Mean	0.8374	0.6799	0.6859	0.5430	0.8192

Table 4: PR-AUC by dataset and variant. Bold marks the best variant for that dataset. The description-only baseline wins on every dataset.

2.5 What the Numbers Say

Description alone is the strongest single text source. The description-only baseline wins on all four datasets. The four D runs sit in a band 0.011 wide (0.8326 to 0.8438). That tightness is what we expected: the description column is identical across all four datasets, only the summary columns change with the LLM provider, so the four D runs are essentially the same model trained four times with the same input.

LLM summaries on their own are worse than the description. S_{ALL} loses about 0.16 PR-AUC on average. S_{GIT} loses about 0.15. S_{CVSS} is the worst at -0.29 . Three things are happening at once. First, the summaries are paraphrases: they turn dense vulnerability text into looser narrative text. Second, two of the three summaries are missing for many CVEs, so those runs train on smaller datasets. Third, the CVSS-metrics summary is templated CVSS prose like “Severity: High; Attack Vector: NETWORK”. The model already sees the same CVSS data as 22 one-hot tabular features, so reading it again as text adds no information and appears to push the description signal out.

Adding all three summaries on top of the description is a wash. The ALL variant concatenates the description and the three summaries. The mean PR-AUC is 0.8192, just 0.018 below the description-only baseline. Per-dataset: GPT loses 0.044, Gemma loses 0.002, Mistral loses 0.007, DeepSeek loses 0.021. The most likely cause is that the extra summary tokens get mean-and-max pooled into the same graph embedding as the description tokens, so the description signal is diluted rather than reinforced.

The variant ordering is the same across providers. On every dataset the order is roughly $D \approx ALL \gg S_{ALL} \approx S_{GIT} > S_{CVSS}$. S_{ALL} and S_{GIT} swap on GPT and Gemma but the broad shape holds. The four LLM providers agree on the relative quality of their own summaries.

Calibration follows the same order. The Brier scores tell the same story as PR-AUC. D and ALL sit in the 0.049 to 0.059 band. S_{ALL} is around 0.07 to 0.10. S_{CVSS} is the worst at 0.10 to 0.11.

2.6 One-Paragraph Summary

After removing the EPSS score from the tabular inputs (the source of earlier 0.99 PR-AUC numbers, which were target leakage), the description-only baseline reaches mean PR-AUC 0.8374 on the four refreshed social-media datasets. Replacing the description with any single LLM summary drops PR-AUC by between 0.15 and 0.29. The templated CVSS summary is the worst because it duplicates information already in the CVSS tabular features. Adding all three summaries on top of the description lands within 0.02 PR-AUC of the description-only baseline. The CVE description is the only text source that materially helps; the LLM summaries do not add net value on this in-distribution corpus.

These are in-distribution results on the data shipped with the Sec4AI4Aec-EPSS-Enhanced repository. They are not deployment numbers. An earlier cross-distribution check on a held-out slice of NVD CVEs saw about an $11\times$ drop in PR-AUC, which is a separate problem caused by sample-selection bias.

3 The Megavul Text-Source Ablation

3.1 Setup

The Megavul side runs the same five-way variant scheme as the social-media side, but on the three Megavul-branch datasets: Mega-GPT, Mega-Gemma and Mega-Mistral. Each dataset covers 9,486 rows and 9,240 unique CVEs. Some CVEs appear in several rows because Megavul links each CVE to one or more vulnerable commits; the pipeline deduplicates by CVE-ID when building the labelled records.

The schema differs from the social-media side. There is no social-media post column, no observation date, no source-platform column. Instead, every row carries a commit URL, the pre-patch and post-patch function code, and CVSS information in two flavours (the original NVD CVSS plus an LLM-augmented v3 estimate when the original is v2-only). The three LLM summaries are different too: a summary of the commit URL, a summary of the vulnerable function code, and a summary of the CVSS metrics. The five variants are:

Variant	Flags passed at training time	What text the model actually sees
D	<code>--summary-source description</code>	The CVE description, nothing else. Baseline.
S_URL	<code>--summary-only-tpg</code> <code>--summary-source commit_url</code>	Only the commit-URL summary.
S_CODE	<code>--summary-only-tpg</code> <code>--summary-source code</code>	Only the LLM summary of the vulnerable function code.
S_CVSS	<code>--summary-only-tpg</code> <code>--summary-source cvss_metrics</code>	Only the CVSS-metrics summary.
ALL	<code>--include-summary-in-tpg</code> <code>--summary-source combined</code>	The description plus all three summaries, joined with double newlines.

Table 5: Megavul five-way variants. Same training command as the social-media side. The soft target is the EPSS score, sourced from the most-recent EPSS recalculation per CVE with fallback to the publication-time EPSS.

Why the prevalence is so much lower than on the social-media side. The Megavul EPSS distribution is heavily skewed. At the same EPSS binarisation threshold of 0.10 used on the social-media side, only about 1.7% of Megavul records are positive, against $\sim 15.5\%$ on the social-media side. The Megavul model therefore trains and is tested on a roughly $7\times$ sparser positive class. The random-baseline PR-AUC equals the prevalence, which is ≈ 0.022 on the Megavul test sets, so any Megavul PR-AUC number should be read as a multiple of 0.022 rather than as an absolute score.

3.2 Per-Run Numbers

Table 6: Test-set metrics for the 15 completed Megavul runs.

Dataset	Variant	PR-AUC	ROC-AUC	F1	Precision	Recall	Brier	N_{test}
Mega-GPT	D	0.3597	0.9232	0.4138	0.3243	0.5714	0.0717	974
Mega-GPT	S_url	0.2136	0.9119	0.2708	0.1733	0.6190	0.0926	972
Mega-GPT	S_code	0.1722	0.8434	0.2222	0.2000	0.2500	0.1250	947
Mega-GPT	S_cvss	0.0700	0.7840	0.0000	0.0000	0.0000	0.0754	974
Mega-GPT	ALL	0.3723	0.9044	0.3860	0.3056	0.5238	0.0991	974
Mega-Gemma	D	0.4102	0.8984	0.3636	0.2941	0.4762	0.0605	974
Mega-Gemma	S_url	0.1939	0.8823	0.3415	0.3500	0.3333	0.0717	974
Mega-Gemma	S_code	0.1756	0.8642	0.2308	0.1579	0.4286	0.1047	974
Mega-Gemma	S_cvss	0.0600	0.7689	0.1143	0.0816	0.1905	0.0826	974
Mega-Gemma	ALL	0.4617	0.9039	0.4571	0.5714	0.3810	0.0326	974
Mega-Mistral	D	0.4978	0.9194	0.3448	0.2273	0.7143	0.0931	974
Mega-Mistral	S_url	0.2482	0.9159	0.3396	0.2812	0.4286	0.1048	974
Mega-Mistral	S_code	0.1885	0.8633	0.1875	0.2727	0.1429	0.0707	974
Mega-Mistral	S_cvss	0.0905	0.8633	0.1778	0.1538	0.2105	0.1015	956
Mega-Mistral	ALL	0.3163	0.9289	0.2727	0.2609	0.2857	0.0643	974

3.3 Means by Variant

Variant	n	Mean PR-AUC	Lift over chance	Change vs D
D	3	0.4226	19.6×	–
S_URL	3	0.2186	10.1×	–0.2040
S_CODE	3	0.1787	8.3×	–0.2439
S_CVSS	3	0.0735	3.4×	–0.3491
ALL	3	0.3834	17.8×	–0.0392

Table 7: Mean PR-AUC across the three Megavul datasets. Lift is the ratio of mean PR-AUC to the random-baseline PR-AUC, which on Megavul equals the test-set prevalence (≈ 0.022).

3.4 Per-Dataset PR-AUC

Dataset	D	S_URL	S_CODE	S_CVSS	ALL
Mega-GPT	0.3597	0.2136	0.1722	0.0700	0.3723
Mega-Gemma	0.4102	0.1939	0.1756	0.0600	0.4617
Mega-Mistral	0.4978	0.2482	0.1885	0.0905	0.3163
Mean	0.4226	0.2186	0.1787	0.0735	0.3834

Table 8: Megavul PR-AUC by dataset and variant. Bold marks the best variant for that dataset. D or ALL wins on every Megavul dataset, identical to the social-media pattern.

3.5 What the Numbers Say (Megavul)

Same variant ordering as on the social-media side. On every Megavul dataset the order is $D \approx ALL \gg S_URL > S_CODE > S_CVSS$. Mega-GPT and Mega-Gemma tilt to ALL; Mega-Mistral tilts to D. The relative ordering matches what we saw on the social-media side: the description is the only single text source that materially helps, the templated CVSS summary is the worst, and concatenating everything is within a few hundredths of the description-only baseline. So the variant ordering is not an artefact of the social-media corpus; it reproduces on a commitment-grounded vulnerability corpus too.

Lower absolute PR-AUC, higher lift over chance. Megavul PR-AUC numbers run from 0.07 to 0.50, much lower than the 0.54 to 0.84 on the social-media side. This is mostly the prevalence, not the model. The Megavul test set has about 21 positives in 974 samples (prevalence 0.022), so the random-baseline PR-AUC is 0.022. The best Megavul run, Mega-Mistral D at PR-AUC 0.498, is about 23× the chance baseline. The best social-media run, GPT D at PR-AUC 0.844, is about 5.4× the chance baseline of 0.155. In lift terms the Megavul model is the stronger ranker; in absolute terms it operates in a much harder data regime.

ROC-AUC stays high across all Megavul variants. Even the worst Megavul variant, Mega-Gemma S_CVSS, has ROC-AUC 0.769. The three best variants per LLM all clear 0.90. ROC-AUC is the better headline metric on data this sparse: it is invariant to prevalence and answers the question that matters operationally, “does the model rank a true positive above a random

negative?”. Brier scores tell a similar story: the best Megavul runs sit in the 0.03 to 0.07 band, comparable to the best social-media runs.

F1 at the default 0.5 threshold understates Megavul performance. The pipeline records F1 at the default decision threshold of 0.5. For Megavul, where positives are $\sim 2\%$, the predicted probabilities cluster well below 0.5, so 0.5-threshold F1 reads low (0.18 to 0.46). When the threshold is tuned on the validation split, which is the standard choice for imbalanced binary reporting, the picture improves. The best Megavul run reaches $F1 \approx 0.45$ at a val-tuned threshold; the weakest still reaches $F1 > 0.06$. FIRST itself ships EPSS with operational thresholds at 0.10 and 0.20, not 0.50, so 0.5-threshold F1 is the wrong choice on these data in the first place.

3.6 One-Paragraph Summary (Megavul)

The five-way text-source ablation reproduces on the Megavul commit-grounded corpus. Description-only is the strongest single source (mean PR-AUC 0.4226, $19.6\times$ random-baseline lift); the templated CVSS summary is the worst (mean 0.0735, $3.4\times$ lift); concatenating description plus all three summaries lands within 0.04 PR-AUC of description-only. ROC-AUC stays in 0.77 to 0.93 across the 15 runs. The lower absolute PR-AUC against the social-media side comes from the $7\times$ sparser positive class (1.7% versus 15.5%), not from a weaker ranker: in lift terms Megavul is comparable or stronger.

4 Top-10 Predictions vs the CISA KEV Catalog

For each of the seven dataset/LLM pairs (four social-media, three Megavul) we picked the best-PR-AUC variant for that LLM and pulled the model’s top-10 highest-confidence test predictions. Each predicted CVE was then checked against the live CISA KEV catalog (catalogVersion 2026.05.08, released 2026-05-08, 1,590 CVEs) and against the live FIRST EPSS API (queried 2026-05-12).

The hit rate against KEV is much higher on the social-media side. That is expected. The social-media datasets cover CVEs from 2020–2024; the KEV catalog itself was created in November 2021; KEV-listed CVEs are exactly the kind of widely discussed vulnerabilities that produce the social-media activity these datasets index. Megavul on the other hand is dominated by long-tail OpenSSL fixes from 2013–2016 that pre-date the KEV catalog by half a decade.

Stored EPSS versus live EPSS. The seven top-10 tables below show a column called Stored EPSS. This is the EPSS value that was held in the dataset at the time the labelled records were built, i.e. the actual soft target the model was trained against. It is not the same as today’s live FIRST EPSS value. FIRST recalculates EPSS daily, so for older CVEs (especially the OpenSSL bugs that dominate the Megavul tables) the live value today can be substantially different from what the dataset held. The two values are reconciled in Table 4.3, which queries the live FIRST API directly. We use the stored value in the top-10 tables because that is the right reference for evaluating the model’s predictions: the model cannot be expected to anticipate EPSS values that FIRST had not yet recomputed at training time.

4.1 Social-Media Side (Description-Only Variant)

Table 9: Top-10 highest-predicted CVEs per social-media LLM, all using the description-only variant (best PR-AUC per LLM). The predicted column is the model probability. The Stored EPSS column is the EPSS value as it was held in the dataset at label-generation time, i.e. the soft target the model was trained to predict; this is not the same as the live FIRST EPSS shown later in Table 4.3, which can differ for older CVEs because EPSS is recalculated daily.

LLM	Rank	CVE / Vendor / Product	Pred.	Stored EPSS	In KEV
GPT	1	CVE-2024-9474 (Palo Alto Networks PAN-OS)	0.9935	0.9748	yes
GPT	2	CVE-2024-23897 (Jenkins CLI)	0.9934	0.9447	yes
GPT	3	CVE-2024-4040 (CrushFTP)	0.9926	0.9427	yes
GPT	4	CVE-2024-4040 (CrushFTP) [†]	0.9926	0.9427	yes
GPT	5	CVE-2024-4040 (CrushFTP) [†]	0.9926	0.9441	yes
GPT	6	CVE-2023-3519 (Citrix NetScaler ADC / Gateway)	0.9924	0.9628	yes
GPT	7	CVE-2024-0204 (Fortra GoAnywhere MFT)	0.9915	0.9332	no
GPT	8	CVE-2024-0204 (Fortra GoAnywhere MFT) [†]	0.9915	0.9332	no
GPT	9	CVE-2018-13379 (Fortinet FortiOS)	0.9914	0.9693	yes
GPT	10	CVE-2023-4966 (Citrix NetScaler ADC / Gateway)	0.9913	0.9438	yes
Gemma	1	CVE-2024-23897 (Jenkins CLI)	0.9940	0.9447	yes
Gemma	2	CVE-2024-0204 (Fortra GoAnywhere MFT)	0.9926	0.9332	no
Gemma	3	CVE-2024-0204 (Fortra GoAnywhere MFT) [†]	0.9926	0.9332	no
Gemma	4	CVE-2018-13379 (Fortinet FortiOS)	0.9885	0.9693	yes
Gemma	5	CVE-2023-35082 (Ivanti EPMM / MobileIron Core)	0.9885	0.9447	yes
Gemma	6	CVE-2023-35082 (Ivanti EPMM / MobileIron Core) [†]	0.9885	0.9447	yes
Gemma	7	CVE-2023-30258 (Magnus-Billing)	0.9880	0.9256	no
Gemma	8	CVE-2023-3519 (Citrix NetScaler ADC / Gateway)	0.9880	0.9628	yes
Gemma	9	CVE-2023-4966 (Citrix NetScaler ADC / Gateway)	0.9880	0.9438	yes
Gemma	10	CVE-2024-28987 (SolarWinds Web Help Desk)	0.9879	0.9589	yes
Mistral	1	CVE-2024-23897 (Jenkins CLI)	0.9974	0.9447	yes
Mistral	2	CVE-2024-9474 (Palo Alto Networks PAN-OS)	0.9947	0.9748	yes
Mistral	3	CVE-2023-3519 (Citrix NetScaler ADC / Gateway)	0.9933	0.9628	yes
Mistral	4	CVE-2024-28987 (SolarWinds Web Help Desk)	0.9884	0.9589	yes

LLM	Rank	CVE / Vendor / Product	Pred.	Stored EPSS	In KEV
Mistral	5	CVE-2009-3960 (Adobe BlazeDS)	0.9881	0.9382	yes
Mistral	6	CVE-2023-50164 (Apache Struts 2)	0.9875	0.9374	no
Mistral	7	CVE-2018-13379 (Fortinet FortiOS)	0.9869	0.9693	yes
Mistral	8	CVE-2023-34362 (Progress MOVEit Transfer)	0.9854	0.9448	yes
Mistral	9	CVE-2023-49103 (ownCloud graphapi)	0.9847	0.9437	yes
Mistral	10	CVE-2023-49103 (ownCloud graphapi) [†]	0.9847	0.9089	yes
DeepSeek	1	CVE-2024-23897 (Jenkins CLI)	0.9965	0.9447	yes
DeepSeek	2	CVE-2023-34039 (VMware Aria Operations for Networks)	0.9940	0.9325	no
DeepSeek	3	CVE-2024-8963 (Ivanti Cloud Services Appliance)	0.9929	0.9680	yes
DeepSeek	4	CVE-2024-4040 (CrushFTP)	0.9920	0.9441	yes
DeepSeek	5	CVE-2024-4040 (CrushFTP) [†]	0.9920	0.9427	yes
DeepSeek	6	CVE-2024-4040 (CrushFTP) [†]	0.9920	0.9427	yes
DeepSeek	7	CVE-2023-3519 (Citrix NetScaler ADC / Gateway)	0.9913	0.9628	yes
DeepSeek	8	CVE-2023-46805 (Ivanti Connect Secure / Policy Secure)	0.9908	0.9440	yes
DeepSeek	9	CVE-2024-9474 (Palo Alto Networks PAN-OS)	0.9907	0.9748	yes
DeepSeek	10	CVE-2022-3236 (Sophos Firewall)	0.9906	0.9286	yes

Rows marked with [†] are repeat appearances of the same CVE in the test set. The source datasets carry multiple rows per CVE because the same CVE was discussed by several different sources (Telegram, Reddit, Hacker News and so on), and each source-mention becomes its own test sample. The model produces nearly identical predictions for them, and they cluster at the top of the ranking because they share the same CVE description text. We show all 10 ranks rather than de-duplicating, so the table reflects exactly what the model output.

Counting unique CVE-IDs, each LLM’s top-10 contains 7 to 9 distinct CVEs and matches KEV on 6 to 9 of them. The four distinct non-KEV CVEs across all four LLMs are: CVE-2024-0204 (Fortra GoAnywhere MFT, authentication bypass), CVE-2023-30258 (MagnusBilling, unauthenticated command injection), CVE-2023-50164 (Apache Struts 2, path traversal to RCE) and CVE-2023-34039 (VMware Aria Operations for Networks, static SSH key authentication bypass). All four have public exploit code or PoCs, all four were the subject of multiple vendor advisories at disclosure time, and all four currently sit in the top 0.3% of FIRST EPSS, as documented in Table 4.3.

4.2 Megavul Side (Best Variant Per LLM)

Table 10: Top-10 highest-predicted CVEs per Megavul LLM, using the best-PR-AUC variant for that LLM (ALL for Mega-GPT and Mega-Gemma, D for Mega-Mistral). The Stored EPSS column is the dataset-stored value, the same EPSS snapshot the model trained against. For the older OpenSSL CVEs dominating this list, the live FIRST EPSS today can be substantially lower or higher; see Table 4.3 for the live values.

LLM	Rank	CVE / Vendor / Product	Pred.	Stored EPSS	In KEV
Mega-Gemma	1	CVE-2014-3505 (OpenSSL DTLS double free)	0.8090	0.9257	no
Mega-Gemma	2	CVE-2014-0195 (OpenSSL DTLS heap overflow)	0.7944	0.9676	no
Mega-Gemma	3	CVE-2014-0160 (OpenSSL Heartbleed)	0.6915	0.9759	yes
Mega-Gemma	4	CVE-2016-6302 (OpenSSL ticket-length checks)	0.6712	0.1520	no
Mega-Gemma	5	CVE-2014-3470 (OpenSSL ECDH null deref)	0.6591	0.9737	no
Mega-Gemma	6	CVE-2014-3515 (OpenSSL ASN.1 type confusion)	0.6347	0.9433	no
Mega-Gemma	7	CVE-2013-0166 (OpenSSL handshake DoS)	0.6258	0.0068	no
Mega-Gemma	8	CVE-2015-0290 (OpenSSL multiblock corrupt)	0.5894	0.0866	no
Mega-Gemma	9	CVE-2015-0289 (OpenSSL PKCS7 null deref)	0.5771	0.0220	no
Mega-Gemma	10	CVE-2014-3569 (OpenSSL no-ssl3 build null deref)	0.5727	0.9025	no
Mega-GPT	1	CVE-2014-3505 (OpenSSL DTLS double free)	0.8889	0.9257	no
Mega-GPT	2	CVE-2015-1792 (OpenSSL CMS null deref)	0.8384	0.0756	no
Mega-GPT	3	CVE-2015-0290 (OpenSSL multiblock corrupt)	0.8154	0.0866	no
Mega-GPT	4	CVE-2014-0160 (OpenSSL Heartbleed)	0.7858	0.9759	yes
Mega-GPT	5	CVE-2016-2181 (OpenSSL DTLS replay protection)	0.7786	0.3711	no
Mega-GPT	6	CVE-2014-0195 (OpenSSL DTLS heap overflow)	0.7393	0.9676	no
Mega-GPT	7	CVE-2016-6302 (OpenSSL ticket-length checks)	0.7139	0.1520	no
Mega-GPT	8	CVE-2014-3569 (OpenSSL no-ssl3 build null deref)	0.7062	0.9025	no
Mega-GPT	9	CVE-2014-3470 (OpenSSL ECDH null deref)	0.6961	0.9737	no
Mega-GPT	10	CVE-2015-0289 (OpenSSL PKCS7 null deref)	0.6892	0.0220	no
Mega-Mistral	1	CVE-2014-3505 (OpenSSL DTLS double free)	0.9448	0.9257	no

LLM	Rank	CVE / Vendor / Product	Pred.	Stored EPSS	In KEV
Mega-Mistral	2	CVE-2014-0195 (OpenSSL DTLS heap overflow)	0.9256	0.9676	no
Mega-Mistral	3	CVE-2014-0160 (OpenSSL Heartbleed)	0.9029	0.9759	yes
Mega-Mistral	4	CVE-2016-2181 (OpenSSL DTLS replay protection)	0.8955	0.3711	no
Mega-Mistral	5	CVE-2014-3470 (OpenSSL ECDH null deref)	0.8937	0.9737	no
Mega-Mistral	6	CVE-2016-6302 (OpenSSL ticket-length checks)	0.8896	0.1520	no
Mega-Mistral	7	CVE-2014-3569 (OpenSSL no-ssl3 build null deref)	0.8618	0.9025	no
Mega-Mistral	8	CVE-2013-0166 (OpenSSL handshake DoS)	0.8412	0.0068	no
Mega-Mistral	9	CVE-2014-2523 (Linux kernel netfilter DCCP)	0.8412	0.0747	no
Mega-Mistral	10	CVE-2015-1790 (OpenSSL PKCS7 null deref)	0.8303	0.0756	no

The Megavul top-10s overlap heavily across the three LLMs because the Megavul corpus has a small set of OpenSSL bugs from 2013–2016 that dominate the high-EPSS tail of the test set. Only one CVE (CVE-2014-0160, Heartbleed) is in the current CISA KEV catalog. This is a KEV-coverage issue, not a model issue: the KEV catalog started accepting entries in November 2021, while the Megavul OpenSSL bugs are mostly from 2013–2016 and so are simply outside the KEV catalog’s effective time window.

4.3 Status of the Non-KEV Top-10 CVEs

For each unique non-KEV CVE in any of the seven top-10 lists we queried the live FIRST EPSS API and a brief web search for current exploitation evidence. The 17 unique non-KEV CVEs split into two groups: four recent CVEs (2023–2024) where the model surfaces high-confidence non-KEV predictions that are very plausibly being exploited, and thirteen older OpenSSL or Linux-kernel CVEs (2013–2016) that pre-date the KEV catalog.

Reading. Of the 17 non-KEV CVEs, all 17 are in the top 11% of FIRST EPSS percentiles (the lowest is 89.36%). 12 of 17 have live EPSS ≥ 0.10 , the same threshold the pipeline uses to binarise the soft target. The four recent non-KEV CVEs all sit above the 99.7th percentile and have public exploit code or PoCs. The thirteen older CVEs pre-date the November 2021 start of the CISA KEV catalog. Put together, the model’s high-confidence non-KEV predictions are not false positives. They are CVEs that FIRST itself ranks at the top of its exploitation-likelihood scale; the model just identified them through patterns in the description text.

Sources for the recent-CVE entries. Exploitation evidence for the four recent CVEs is aggregated from the following public sources, all accessed 2026-05-12: CVE-2024-0204 (Tenable, Rapid7, Help Net Security, UpGuard); CVE-2023-50164 (Akamai, Trend Micro, Cybersecurity Dive, Palo Alto Networks Unit 42, Qualys ThreatPROTECT); CVE-2023-34039 (Help Net Security, Security Boulevard, Arctic Wolf, The Hacker News); CVE-2023-30258 (Wiz vulnerability database, CVE Details). Live EPSS scores were retrieved from the FIRST EPSS API.

CVE	Live EPSS	Percentile	Exploitation evidence (May 2026)
<i>Recent (2023–2024), not in KEV but high EPSS</i>			
CVE-2024-0204	0.9305	99.79%	Fortra GoAnywhere MFT auth bypass; PoC public January 2024; Shadowserver observed exploit attempts; advisories from Tenable, Rapid7, Help Net Security and others.
CVE-2023-50164	0.9286	99.77%	Apache Struts 2 path traversal to RCE; PoC published December 2023; active exploitation reported by Akamai, Trend Micro, Cybersecurity Dive.
CVE-2023-34039	0.9317	99.80%	VMware Aria Operations for Networks static SSH key, authentication bypass; PoC by Sina Kheirkhah; Broadcom CVSS 9.8 advisory.
CVE-2023-30258	0.9368	99.85%	MagnusBilling unauthenticated command injection; CVSS 9.8; ranked at the 99.85th EPSS percentile.
<i>Older (2013–2016), pre-date KEV catalog</i>			
CVE-2014-0195	0.9275	99.76%	OpenSSL DTLS fragment heap overflow, RCE class. Multiple Metasploit modules historically.
CVE-2014-3470	0.9140	99.67%	OpenSSL ECDH client null deref.
CVE-2014-3515	0.4866	97.78%	OpenSSL ASN.1 type confusion.
CVE-2014-3505	0.4688	97.70%	OpenSSL DTLS double free.
CVE-2015-0290	0.3256	96.90%	OpenSSL multiblock corrupt.
CVE-2016-2181	0.2427	96.14%	OpenSSL DTLS replay protection.
CVE-2015-1792	0.1236	93.95%	OpenSSL CMS null deref.
CVE-2016-6302	0.1038	93.27%	OpenSSL ticket-length checks.
CVE-2015-1790	0.0961	92.94%	OpenSSL PKCS7 null deref.
CVE-2013-0166	0.0951	92.90%	OpenSSL handshake DoS.
CVE-2014-3569	0.0756	91.89%	OpenSSL no-ssl3 build null deref.
CVE-2015-0289	0.0579	90.57%	OpenSSL PKCS7 null deref (related).
CVE-2014-2523	0.0463	89.36%	Linux kernel netfilter DCCP.

Table 11: Live status of every non-KEV CVE that appears in any of the seven top-10 prediction lists. Live EPSS and percentile from the FIRST EPSS API on 2026-05-12.

5 NVD/KEV Binary Rerun

This run is separate from the two text-source ablations. It uses the older balanced NVD/KEV dataset. The target here is the binary KEV membership label: 1 means the CVE is in the CISA KEV catalog snapshot used at label-generation time, 0 means it is not.

The training command uses these flags: `--backbone multiview`, `--hybrid`, `--label-mode binary` and `--skip-collect`. This run does not use any LLM summary and does not enable security edges. Unlike the EPSS soft-label runs, it keeps the EPSS score and percentile in the tabular branch. That is not direct target leakage (the label is KEV membership, not EPSS), but EPSS is a strong external risk signal, so this should be read as a hybrid KEV predictor with external risk input rather than as a text-only result.

At threshold 0.5 the test confusion matrix is TP = 98, FP = 11, TN = 472, FN = 23. The best-F1 threshold from the saved predictions is around 0.068. At that threshold F1 rises to about 0.8735, with precision 0.8629 and recall 0.8843. The table reports 0.5-threshold metrics because those are what the pipeline records by default.

The fresh rerun is much stronger than the older saved result. The most likely cause is that the

Property	Value
Dataset family	older balanced NVD/KEV dataset
Dataset size	4,015 CVEs
Test samples	604
Test positives	121
Test prevalence	20.03%
Backbone	multiview
Model type	hybrid (graph + tabular)
Input channels	781
Tabular dimensions	57 (EPSS kept as input here)
Edge types	13
Epochs completed	24
Best validation PR-AUC	0.9247 at epoch 9
Best validation F1	0.8511 at epoch 10

Table 12: NVD/KEV rerun setup.

Run	PR-AUC	ROC-AUC	F1	Precision	Recall	Brier	Loss
Previous saved run	0.7592	0.8923	0.6917	0.6975	0.6860	0.1073	2.0044
Fresh rerun	0.9375	0.9749	0.8522	0.8991	0.8099	0.0479	0.9002
Change	+0.1783	+0.0827	+0.1605	+0.2016	+0.1240	−0.0594	−1.1042

Table 13: Fresh NVD/KEV rerun versus the previous saved run.

rerun was built on a freshly processed dataset with the current 57-dim tabular vector, while the older run used a stale graph cache that produced only 53 tabular dimensions.

6 NVD/KEV Temporal Shift

This run measures temporal generalisation. The model is trained and validated on CVEs published between 2020 and 2022, then tested on a separate 2023–2024 slice. This is harder than a random split because the test CVEs come from years the model has not seen.

The target is still KEV membership. The model has access to CVE text, CVSS and CWE metadata, EPSS fields, and exploit and source features.

6.1 Same Window With EPSS Removed

A follow-up run trained on the same 2020–2022 window and tested on the same 2023–2024 window, but with the EPSS score and percentile removed from the tabular inputs (`--no-epss-feature`). The setup is otherwise identical. This run measures how much of the temporal-shift performance comes from the EPSS input.

Removing EPSS from the input drops PR-AUC by 0.14 on the temporal test set. The drop is real but the model still ranks well above random (PR-AUC 0.70 at prevalence 0.095 is about $7.4\times$ chance). On this dataset the text and CVSS features carry most of the signal; EPSS is a useful but not load-bearing additional input.

Property	Value
Train window	2020-01-02 to 2022-12-30
Test window	2023-01-01 to 2024-12-30
Train records	7,487 (487 positive, 6.50%)
Test records	3,316 (316 positive, 9.53%)
Backbone	multiview
Model type	hybrid (graph + tabular)
Tabular dimensions	57
Edge types	13
EPSS in tabular input	yes
Security edges	no
Epochs completed	27
Best validation PR-AUC	0.8499 at epoch 7
Best validation F1	0.7692 at epoch 18

Table 14: Temporal-shift setup.

Setting	PR-AUC	ROC-AUC	F1	Precision	Recall	Brier
EPSS in tabular	0.8456	0.9598	0.7806	0.8253	0.7405	0.0676
EPSS removed	0.7041	0.9213	0.6519	0.7421	0.5808	0.0921
Change	-0.1415	-0.0385	-0.1287	-0.0832	-0.1597	+0.0245

Table 15: Temporal-shift run with EPSS in versus out of the tabular branch. Same train/test split.

7 NVD/KEV No-EPSS Temporal Extrapolation

A third NVD/KEV run extrapolates further: train on 2020 only, test on 2021–2026. EPSS is removed from the tabular input. This is the hardest temporal evaluation: small training window, very wide test window, no EPSS hint.

Property	Value
Train window	2020-01-02 to 2020-12-30
Test window	2021-01-04 to 2026-12-30
Train records	1,500
Test records	9,303
Test positives	785 (8.44%)
EPSS in tabular input	no

Table 16: No-EPSS temporal-extrapolation setup.

PR-AUC drops to 0.49 on this evaluation, but is still about $5.8\times$ the chance baseline of 0.084. ROC-AUC stays at 0.88, which means the ranking quality survives the temporal shift even without EPSS as an input. The big change is in calibration and recall: the model only catches 40.8% of the test-set positives at the default threshold. A lower decision threshold would recover most of the recall at the cost of precision; the val-tuned threshold for this run is 0.226, well below 0.5.

Run	PR-AUC	ROC-AUC	F1	Precision	Recall	Brier
2020 train, 2021–2026 test, no EPSS	0.4853	0.8773	0.4860	0.6018	0.4076	0.0738

Table 17: No-EPSS temporal extrapolation.